

Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 — Risk Scoring (scanner-primary CVSS) · Commit `61ed8c3` · Generated 2026-07-04 · Model: `risk = 0.5·CVE_severity + 0.3·exposure + 0.2·business_criticality`

Ranked remediation backlog

#	Coordinate	Risk	Band	Top CVE / issue	Fix version
1	<code>com.fastxml.jackson.core:jackson-databind:2.9.8</code>	7.8	CRITICAL	Typosquat — impersonates <code>com.fasterxml.jackson.core</code>	remove coordinate
2	<code>org.apache.logging.log4j:log4j-core:2.14.1</code>	7.8	HIGH	CVE-2021-44228 — Log4Shell (10.0)	2.25.4
3	<code>com.fasterxml.jackson.core:jackson-databind:2.9.8</code>	7.8	HIGH	CVE-2019-14379 (9.8), 53 more	2.16.0
4	<code>org.apache.logging.log4j:log4j-api:2.14.1</code>	6.8	HIGH	CVE-2026-34479 (7.5)	2.25.4
5	<code>mysql:mysql-connector-java:8.0.30</code>	6.7	HIGH	CVE-2023-22102 (8.3) + GPL-2.0 license violation	8.1.0
6	<code>com.google.protobuf:protobuf-java:3.19.4</code>	6.7	HIGH	CVE-2024-7254 (7.5)	3.25.5
7	<code>com.google.guava:guava:24.1.1-jre</code>	6.3	HIGH	CVE-2023-2976 (7.1)	32.0.0
8	<code>com.fasterxml.jackson.core:jackson-annotations:2.9.0</code>	5.5	MEDIUM	CVE-2018-1000873 (6.5)	2.9.8
9	<code>commons-io:commons-io:2.4</code>	5.2	MEDIUM	CVE-2021-29425 (4.8)	2.14.0
10	<code>org.apache.commons:commons-lang3:3.4</code>	5.2	MEDIUM	CVE-2025-48924 (5.3)	3.18.0
11	<code>org.junit.jupiter:junit-jupiter:5.10.2</code>	1.7	LOW	none — outdated only (test scope)	6.1.1

Component scores

Coordinate	CVE severity	Exposure	Business criticality	Weighted risk
<code>com.fastxml.jackson.core:jackson-databind:2.9.8</code> (typosquat)	10.0 †	8.0	2.0	7.8
<code>org.apache.logging.log4j:log4j-core:2.14.1</code>	10.0	8.0	2.0	7.8
<code>com.fasterxml.jackson.core:jackson-databind:2.9.8</code>	10.0	8.0	2.0	7.8
<code>org.apache.logging.log4j:log4j-api:2.14.1</code>	8.0	8.0	2.0	6.8
<code>mysql:mysql-connector-java:8.0.30</code>	8.3	7.0	2.0	6.7
<code>com.google.protobuf:protobuf-java:3.19.4</code>	9.0	6.0	2.0	6.7
<code>com.google.guava:guava:24.1.1-jre</code>	7.6	7.0	2.0	6.3

<code>com.fasterxml.jackson.core:jackson-annotations:2.9.0</code>	6.5	6.0	2.0	5.5
<code>commons-io:commons-io:2.4</code>	5.3	7.0	2.0	5.2
<code>org.apache.commons:commons-lang3:3.4</code>	5.3	7.0	2.0	5.2
<code>org.junit.jupiter:junit-jupiter:5.10.2</code>	0.0	5.0	1.0	1.7

† No scannable CVSS exists for an unresolvable coordinate; scored at 10.0 as an analyst judgment call reflecting the arbitrary-code-execution risk of a typosquat, and the band is manually floored to **CRITICAL** regardless of the weighted formula (see rationale below).

Any dependency with a **CRITICAL-severity CVE** is floored at band **HIGH** per the scoring policy — this applies to `log4j-core` (CVE-2021-44228, CVSS 10.0) and `jackson-databind` (24 CRITICAL CVEs), both of which land at HIGH from the weighted formula anyway (7.8).

Priority recommendations

1. **P0 — Remove the typosquatted dependency.** `com.fastxml.jackson.core:jackson-databind:2.9.8` does not resolve and impersonates a real coordinate already declared in `pom.xml`. Delete the block; no functional loss since the legitimate `com.fasterxml.jackson.core:jackson-databind` dependency remains.
2. **P0 — Patch Log4Shell.** Upgrade `log4j-core` and `log4j-api` 2.14.1 → **2.25.4** together (this also clears two 2026-disclosed CVEs beyond the original Log4Shell/Log4Shell-2 pair). This library is actively imported by `DiscountCalculator.java`.
3. **P1 — Upgrade jackson-databind.** 2.9.8 carries 54 CVEs (24 CRITICAL). Move to at least **2.16.0** to clear all currently known issues, keeping `jackson-annotations` / `jackson-core` aligned.
4. **P1 — Replace or patch the MySQL connector.** `mysql-connector-java` 8.0.30 has both a HIGH CVE (CVE-2023-22102, malicious-server RCE, fixed in 8.1.0) **and** a GPL-2.0 license-policy violation in a permissive-only project — resolve both by upgrading and confirming license terms of the target version, or by evaluating the MIT-licensed `mysql:mysql-connector-j` successor artifact.
5. **P2 — Upgrade guava and protobuf-java.** `guava` → 32.0.0+ (HIGH, CVE-2023-2976) and `protobuf-java` → 3.25.5 (transitive via `mysql-connector-java`; will likely resolve automatically once the connector is upgraded).
6. **P3 — Routine hygiene.** `commons-io` → 2.14.0+, `commons-lang3` → 3.18.0+, `jackson-annotations` → 2.9.8+, `junit-jupiter` → 6.x (test scope, no CVE, low urgency).

Machine-readable source: `depscan-risk-report.json`. Generated by the *Dependency & Supply-Chain Plugin* — Stage 2. Ready for the *Auto-Remediation Skill* (Stage 3) and the *PR Validation Agent* (Stage 4).